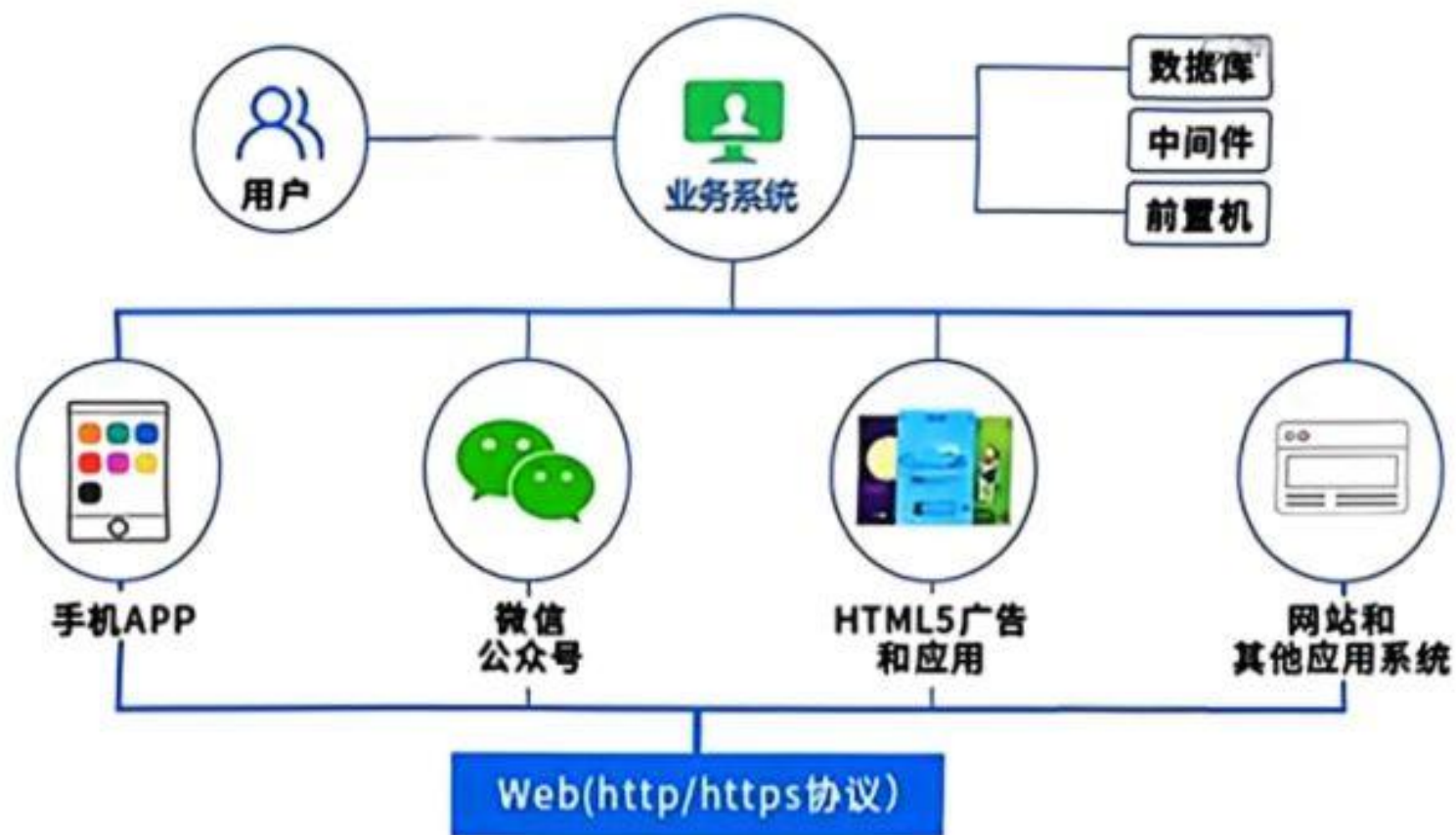
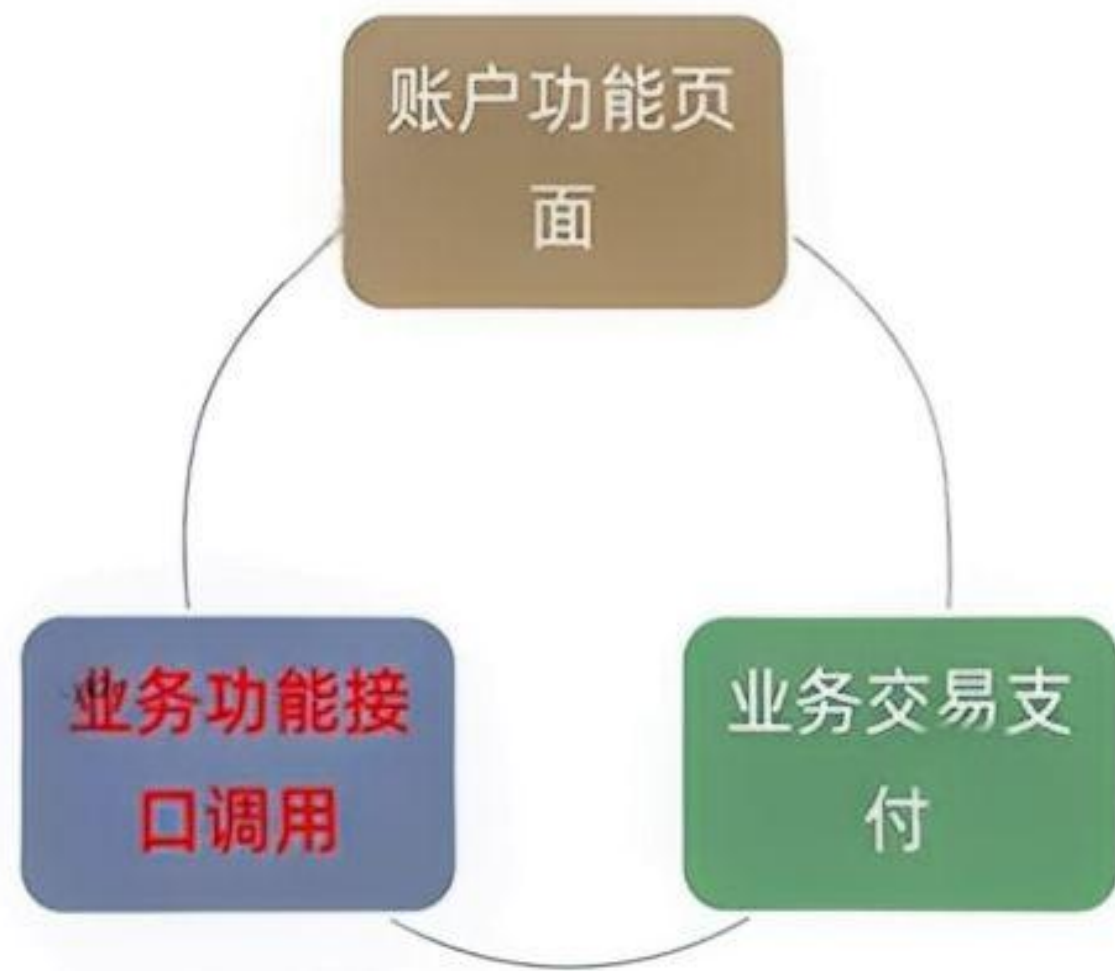


业务逻辑漏洞

如何形成



常见漏洞出现点



业务功能接口调用

业务功能接口调用处容易出现的就是未授权访问漏洞或者业务功能接口被恶意调用。



业务功能接口调用案例1

如果在mobile 的字段用","来拼接另一个手机号, 那么此时会发生什么事情呢? 请看VCR。

```
POST /xxx/SendMobileSMS HTTP/1.1
Host: x.x.x.x
...
{
  "xxx": "xxxxxxx",
  "mobile": "17711111111,17722222222"
}
```

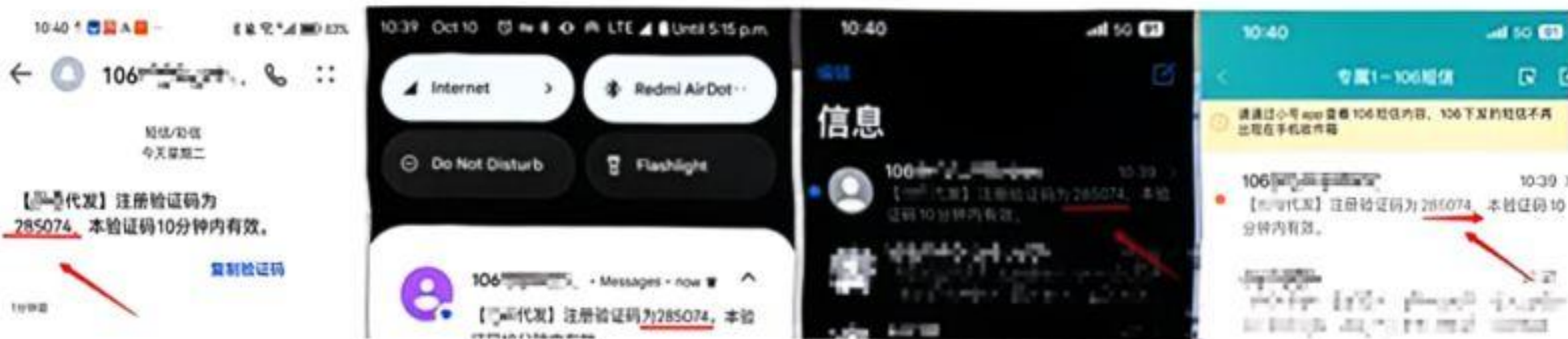
业务功能接口调用案例1

两个手机号都同时收到了验证码，而且验证码的内容一模一样。



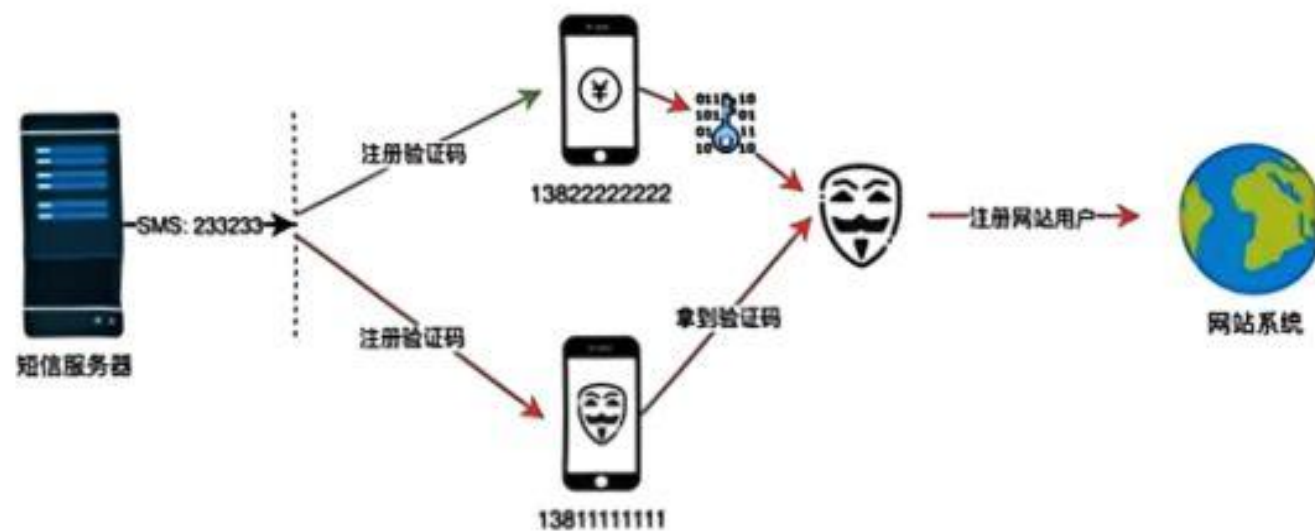
业务功能接口调用案例1

顾名思义，这种就是批量发送接口，用来做横向短信轰炸很合理，利用我们上述的姿势，直接使用逗号拼接多个手机号进行发送。如果在加上没有其他限制条件，危害极大。



业务功能接口调用案例1

比如下图这种利用这种漏洞来任意用户注册，黑客使用 13811111111 的手机号即可窃取到 13822222222 的验证码，然后即可伪造成 13822222222 的身份来注册网站用户，达到伪造任意用户注册。



业务功能接口调用案例2

注册、忘记密码、修改密码处都存在发送短信功能，但可能会设置参数值的不同来判断是执行功能接口。

Go Cancel < >

Request

Raw Params Headers Hex

```
POST /api/sendCaptcha? HTTP/1.1
Host:
Content-Type: application/json; charset=UTF-8
Accept: application/json, */*; q=0.01
Origin:
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/55.0.3883.87 Safari/537.36
Content-Type: application/json; charset=UTF-8
Referer:
Accept-Language: zh-CN, zh;q=0.8
Cookie: _qddaz=QD.s72tvc.v5cflk.jh5v6bvw; tencentSig=922371072;
ISOSessionId=9a5ad557-0060-4c3a-a07c-86e82f3002ad;
SESSIONID=01899d06c1177a664d3fc4f8df1e2733
Connection: close
```

r=1875512119&t=mobile&p=g56y&r=2

注册处，发送短信验证码，发现r=2时，会验证图形验证码，再次发送就失败

但是，将r改为58时，可以发送成功，但是再次发送，发现有1分钟内不允许多次发送的限制，但是依然可以模拟短信轰炸

Response

Raw Headers Hex

```
utf-8, windows-1250, windows-1251, windows-1252, windows-1253, windows-1254,
windows-1255, windows-1256, windows-1257, windows-1258, windows-31j,
x-big5-hkscs-2001, x-big5-solaris, x-compound_text, x-euc-jp-linux, x-euc-tw,
x-eucjp-open, x-ibm1006, x-ibm1025, x-ibm1046, x-ibm1097, x-ibm1098, x-ibm1112,
x-ibm1122, x-ibm1123, x-ibm1124, x-ibm1166, x-ibm1304, x-ibm1383,
x-ibm300, x-ibm33722, x-ibm337, x-ibm833, x-ibm834, x-ibm835, x-ibm836,
x-ibm837, x-ibm838, x-ibm839, x-ibm840, x-ibm841, x-ibm842, x-ibm843,
x-ibm844, x-ibm845, x-ibm846, x-ibm847, x-ibm848, x-ibm849, x-ibm850,
x-ibm851, x-ibm852, x-ibm853, x-ibm854, x-ibm855, x-ibm856, x-ibm857,
x-ibm858, x-ibm859, x-ibm860, x-ibm861, x-ibm862, x-ibm863, x-ibm864,
x-ibm865, x-ibm866, x-ibm867, x-ibm868, x-ibm869, x-ibm870, x-ibm871,
x-ibm872, x-ibm873, x-ibm874, x-ibm875, x-ibm876, x-ibm877, x-ibm878,
x-ibm879, x-ibm880, x-ibm881, x-ibm882, x-ibm883, x-ibm884, x-ibm885,
x-ibm886, x-ibm887, x-ibm888, x-ibm889, x-ibm890, x-ibm891, x-ibm892,
x-ibm893, x-ibm894, x-ibm895, x-ibm896, x-ibm897, x-ibm898, x-ibm899,
x-ibm900, x-ibm901, x-ibm902, x-ibm903, x-ibm904, x-ibm905, x-ibm906,
x-ibm907, x-ibm908, x-ibm909, x-ibm910, x-ibm911, x-ibm912, x-ibm913,
x-ibm914, x-ibm915, x-ibm916, x-ibm917, x-ibm918, x-ibm919, x-ibm920,
x-ibm921, x-ibm922, x-ibm923, x-ibm924, x-ibm925, x-ibm926, x-ibm927,
x-ibm928, x-ibm929, x-ibm930, x-ibm931, x-ibm932, x-ibm933, x-ibm934,
x-ibm935, x-ibm936, x-ibm937, x-ibm938, x-ibm939, x-ibm940, x-ibm941,
x-ibm942, x-ibm943, x-ibm944, x-ibm945, x-ibm946, x-ibm947, x-ibm948,
x-ibm949, x-ibm950, x-ibm951, x-ibm952, x-ibm953, x-ibm954, x-ibm955,
x-ibm956, x-ibm957, x-ibm958, x-ibm959, x-ibm960, x-ibm961, x-ibm962,
x-ibm963, x-ibm964, x-ibm965, x-ibm966, x-ibm967, x-ibm968, x-ibm969,
x-ibm970, x-ibm971, x-ibm972, x-ibm973, x-ibm974, x-ibm975, x-ibm976,
x-ibm977, x-ibm978, x-ibm979, x-ibm980, x-ibm981, x-ibm982, x-ibm983,
x-ibm984, x-ibm985, x-ibm986, x-ibm987, x-ibm988, x-ibm989, x-ibm990,
x-ibm991, x-ibm992, x-ibm993, x-ibm994, x-ibm995, x-ibm996, x-ibm997,
x-ibm998, x-ibm999, x-ibm1000, x-ibm1001, x-ibm1002, x-ibm1003,
x-ibm1004, x-ibm1005, x-ibm1006, x-ibm1007, x-ibm1008, x-ibm1009,
x-ibm1010, x-ibm1011, x-ibm1012, x-ibm1013, x-ibm1014, x-ibm1015,
x-ibm1016, x-ibm1017, x-ibm1018, x-ibm1019, x-ibm1020, x-ibm1021,
x-ibm1022, x-ibm1023, x-ibm1024, x-ibm1025, x-ibm1026, x-ibm1027,
x-ibm1028, x-ibm1029, x-ibm1030, x-ibm1031, x-ibm1032, x-ibm1033,
x-ibm1034, x-ibm1035, x-ibm1036, x-ibm1037, x-ibm1038, x-ibm1039,
x-ibm1040, x-ibm1041, x-ibm1042, x-ibm1043, x-ibm1044, x-ibm1045,
x-ibm1046, x-ibm1047, x-ibm1048, x-ibm1049, x-ibm1050, x-ibm1051,
x-ibm1052, x-ibm1053, x-ibm1054, x-ibm1055, x-ibm1056, x-ibm1057,
x-ibm1058, x-ibm1059, x-ibm1060, x-ibm1061, x-ibm1062, x-ibm1063,
x-ibm1064, x-ibm1065, x-ibm1066, x-ibm1067, x-ibm1068, x-ibm1069,
x-ibm1070, x-ibm1071, x-ibm1072, x-ibm1073, x-ibm1074, x-ibm1075,
x-ibm1076, x-ibm1077, x-ibm1078, x-ibm1079, x-ibm1080, x-ibm1081,
x-ibm1082, x-ibm1083, x-ibm1084, x-ibm1085, x-ibm1086, x-ibm1087,
x-ibm1088, x-ibm1089, x-ibm1090, x-ibm1091, x-ibm1092, x-ibm1093,
x-ibm1094, x-ibm1095, x-ibm1096, x-ibm1097, x-ibm1098, x-ibm1099,
x-ibm1100, x-ibm1101, x-ibm1102, x-ibm1103, x-ibm1104, x-ibm1105,
x-ibm1106, x-ibm1107, x-ibm1108, x-ibm1109, x-ibm1110, x-ibm1111,
x-ibm1112, x-ibm1113, x-ibm1114, x-ibm1115, x-ibm1116, x-ibm1117,
x-ibm1118, x-ibm1119, x-ibm1120, x-ibm1121, x-ibm1122, x-ibm1123,
x-ibm1124, x-ibm1125, x-ibm1126, x-ibm1127, x-ibm1128, x-ibm1129,
x-ibm1130, x-ibm1131, x-ibm1132, x-ibm1133, x-ibm1134, x-ibm1135,
x-ibm1136, x-ibm1137, x-ibm1138, x-ibm1139, x-ibm1140, x-ibm1141,
x-ibm1142, x-ibm1143, x-ibm1144, x-ibm1145, x-ibm1146, x-ibm1147,
x-ibm1148, x-ibm1149, x-ibm1150, x-ibm1151, x-ibm1152, x-ibm1153,
x-ibm1154, x-ibm1155, x-ibm1156, x-ibm1157, x-ibm1158, x-ibm1159,
x-ibm1160, x-ibm1161, x-ibm1162, x-ibm1163, x-ibm1164, x-ibm1165,
x-ibm1166, x-ibm1167, x-ibm1168, x-ibm1169, x-ibm1170, x-ibm1171,
x-ibm1172, x-ibm1173, x-ibm1174, x-ibm1175, x-ibm1176, x-ibm1177,
x-ibm1178, x-ibm1179, x-ibm1180, x-ibm1181, x-ibm1182, x-ibm1183,
x-ibm1184, x-ibm1185, x-ibm1186, x-ibm1187, x-ibm1188, x-ibm1189,
x-ibm1190, x-ibm1191, x-ibm1192, x-ibm1193, x-ibm1194, x-ibm1195,
x-ibm1196, x-ibm1197, x-ibm1198, x-ibm1199, x-ibm1200, x-ibm1201,
x-ibm1202, x-ibm1203, x-ibm1204, x-ibm1205, x-ibm1206, x-ibm1207,
x-ibm1208, x-ibm1209, x-ibm1210, x-ibm1211, x-ibm1212, x-ibm1213,
x-ibm1214, x-ibm1215, x-ibm1216, x-ibm1217, x-ibm1218, x-ibm1219,
x-ibm1220, x-ibm1221, x-ibm1222, x-ibm1223, x-ibm1224, x-ibm1225,
x-ibm1226, x-ibm1227, x-ibm1228, x-ibm1229, x-ibm1230, x-ibm1231,
x-ibm1232, x-ibm1233, x-ibm1234, x-ibm1235, x-ibm1236, x-ibm1237,
x-ibm1238, x-ibm1239, x-ibm1240, x-ibm1241, x-ibm1242, x-ibm1243,
x-ibm1244, x-ibm1245, x-ibm1246, x-ibm1247, x-ibm1248, x-ibm1249,
x-ibm1250, x-ibm1251, x-ibm1252, x-ibm1253, x-ibm1254, x-ibm1255,
x-ibm1256, x-ibm1257, x-ibm1258, x-ibm1259, x-ibm1260, x-ibm1261,
x-ibm1262, x-ibm1263, x-ibm1264, x-ibm1265, x-ibm1266, x-ibm1267,
x-ibm1268, x-ibm1269, x-ibm1270, x-ibm1271, x-ibm1272, x-ibm1273,
x-ibm1274, x-ibm1275, x-ibm1276, x-ibm1277, x-ibm1278, x-ibm1279,
x-ibm1280, x-ibm1281, x-ibm1282, x-ibm1283, x-ibm1284, x-ibm1285,
x-ibm1286, x-ibm1287, x-ibm1288, x-ibm1289, x-ibm1290, x-ibm1291,
x-ibm1292, x-ibm1293, x-ibm1294, x-ibm1295, x-ibm1296, x-ibm1297,
x-ibm1298, x-ibm1299, x-ibm1300, x-ibm1301, x-ibm1302, x-ibm1303,
x-ibm1304, x-ibm1305, x-ibm1306, x-ibm1307, x-ibm1308, x-ibm1309,
x-ibm1310, x-ibm1311, x-ibm1312, x-ibm1313, x-ibm1314, x-ibm1315,
x-ibm1316, x-ibm1317, x-ibm1318, x-ibm1319, x-ibm1320, x-ibm1321,
x-ibm1322, x-ibm1323, x-ibm1324, x-ibm1325, x-ibm1326, x-ibm1327,
x-ibm1328, x-ibm1329, x-ibm1330, x-ibm1331, x-ibm1332, x-ibm1333,
x-ibm1334, x-ibm1335, x-ibm1336, x-ibm1337, x-ibm1338, x-ibm1339,
x-ibm1340, x-ibm1341, x-ibm1342, x-ibm1343, x-ibm1344, x-ibm1345,
x-ibm1346, x-ibm1347, x-ibm1348, x-ibm1349, x-ibm1350, x-ibm1351,
x-ibm1352, x-ibm1353, x-ibm1354, x-ibm1355, x-ibm1356, x-ibm1357,
x-ibm1358, x-ibm1359, x-ibm1360, x-ibm1361, x-ibm1362, x-ibm1363,
x-ibm1364, x-ibm1365, x-ibm1366, x-ibm1367, x-ibm1368, x-ibm1369,
x-ibm1370, x-ibm1371, x-ibm1372, x-ibm1373, x-ibm1374, x-ibm1375,
x-ibm1376, x-ibm1377, x-ibm1378, x-ibm1379, x-ibm1380, x-ibm1381,
x-ibm1382, x-ibm1383, x-ibm1384, x-ibm1385, x-ibm1386, x-ibm1387,
x-ibm1388, x-ibm1389, x-ibm1390, x-ibm1391, x-ibm1392, x-ibm1393,
x-ibm1394, x-ibm1395, x-ibm1396, x-ibm1397, x-ibm1398, x-ibm1399,
x-ibm1400, x-ibm1401, x-ibm1402, x-ibm1403, x-ibm1404, x-ibm1405,
x-ibm1406, x-ibm1407, x-ibm1408, x-ibm1409, x-ibm1410, x-ibm1411,
x-ibm1412, x-ibm1413, x-ibm1414, x-ibm1415, x-ibm1416, x-ibm1417,
x-ibm1418, x-ibm1419, x-ibm1420, x-ibm1421, x-ibm1422, x-ibm1423,
x-ibm1424, x-ibm1425, x-ibm1426, x-ibm1427, x-ibm1428, x-ibm1429,
x-ibm1430, x-ibm1431, x-ibm1432, x-ibm1433, x-ibm1434, x-ibm1435,
x-ibm1436, x-ibm1437, x-ibm1438, x-ibm1439, x-ibm1440, x-ibm1441,
x-ibm1442, x-ibm1443, x-ibm1444, x-ibm1445, x-ibm1446, x-ibm1447,
x-ibm1448, x-ibm1449, x-ibm1450, x-ibm1451, x-ibm1452, x-ibm1453,
x-ibm1454, x-ibm1455, x-ibm1456, x-ibm1457, x-ibm1458, x-ibm1459,
x-ibm1460, x-ibm1461, x-ibm1462, x-ibm1463, x-ibm1464, x-ibm1465,
x-ibm1466, x-ibm1467, x-ibm1468, x-ibm1469, x-ibm1470, x-ibm1471,
x-ibm1472, x-ibm1473, x-ibm1474, x-ibm1475, x-ibm1476, x-ibm1477,
x-ibm1478, x-ibm1479, x-ibm1480, x-ibm1481, x-ibm1482, x-ibm1483,
x-ibm1484, x-ibm1485, x-ibm1486, x-ibm1487, x-ibm1488, x-ibm1489,
x-ibm1490, x-ibm1491, x-ibm1492, x-ibm1493, x-ibm1494, x-ibm1495,
x-ibm1496, x-ibm1497, x-ibm1498, x-ibm1499, x-ibm1500, x-ibm1501,
x-ibm1502, x-ibm1503, x-ibm1504, x-ibm1505, x-ibm1506, x-ibm1507,
x-ibm1508, x-ibm1509, x-ibm1510, x-ibm1511, x-ibm1512, x-ibm1513,
x-ibm1514, x-ibm1515, x-ibm1516, x-ibm1517, x-ibm1518, x-ibm1519,
x-ibm1520, x-ibm1521, x-ibm1522, x-ibm1523, x-ibm1524, x-ibm1525,
x-ibm1526, x-ibm1527, x-ibm1528, x-ibm1529, x-ibm1530, x-ibm1531,
x-ibm1532, x-ibm1533, x-ibm1534, x-ibm1535, x-ibm1536, x-ibm1537,
x-ibm1538, x-ibm1539, x-ibm1540, x-ibm1541, x-ibm1542, x-ibm1543,
x-ibm1544, x-ibm1545, x-ibm1546, x-ibm1547, x-ibm1548, x-ibm1549,
x-ibm1550, x-ibm1551, x-ibm1552, x-ibm1553, x-ibm1554, x-ibm1555,
x-ibm1556, x-ibm1557, x-ibm1558, x-ibm1559, x-ibm1560, x-ibm1561,
x-ibm1562, x-ibm1563, x-ibm1564, x-ibm1565, x-ibm1566, x-ibm1567,
x-ibm1568, x-ibm1569, x-ibm1570, x-ibm1571, x-ibm1572, x-ibm1573,
x-ibm1574, x-ibm1575, x-ibm1576, x-ibm1577, x-ibm1578, x-ibm1579,
x-ibm1580, x-ibm1581, x-ibm1582, x-ibm1583, x-ibm1584, x-ibm1585,
x-ibm1586, x-ibm1587, x-ibm1588, x-ibm1589, x-ibm1590, x-ibm1591,
x-ibm1592, x-ibm1593, x-ibm1594, x-ibm1595, x-ibm1596, x-ibm1597,
x-ibm1598, x-ibm1599, x-ibm1600, x-ibm1601, x-ibm1602, x-ibm1603,
x-ibm1604, x-ibm1605, x-ibm1606, x-ibm1607, x-ibm1608, x-ibm1609,
x-ibm1610, x-ibm1611, x-ibm1612, x-ibm1613, x-ibm1614, x-ibm1615,
x-ibm1616, x-ibm1617, x-ibm1618, x-ibm1619, x-ibm1620, x-ibm1621,
x-ibm1622, x-ibm1623, x-ibm1624, x-ibm1625, x-ibm1626, x-ibm1627,
x-ibm1628, x-ibm1629, x-ibm1630, x-ibm1631, x-ibm1632, x-ibm1633,
x-ibm1634, x-ibm1635, x-ibm1636, x-ibm1637, x-ibm1638, x-ibm1639,
x-ibm1640, x-ibm1641, x-ibm1642, x-ibm1643, x-ibm1644, x-ibm1645,
x-ibm1646, x-ibm1647, x-ibm1648, x-ibm1649, x-ibm1650, x-ibm1651,
x-ibm1652, x-ibm1653, x-ibm1654, x-ibm1655, x-ibm1656, x-ibm1657,
x-ibm1658, x-ibm1659, x-ibm1660, x-ibm1661, x-ibm1662, x-ibm1663,
x-ibm1664, x-ibm1665, x-ibm1666, x-ibm1667, x-ibm1668, x-ibm1669,
x-ibm1670, x-ibm1671, x-ibm1672, x-ibm1673, x-ibm1674, x-ibm1675,
x-ibm1676, x-ibm1677, x-ibm1678, x-ibm1679, x-ibm1680, x-ibm1681,
x-ibm1682, x-ibm1683, x-ibm1684, x-ibm1685, x-ibm1686, x-ibm1687,
x-ibm1688, x-ibm1689, x-ibm1690, x-ibm1691, x-ibm1692, x-ibm1693,
x-ibm1694, x-ibm1695, x-ibm1696, x-ibm1697, x-ibm1698, x-ibm1699,
x-ibm1700, x-ibm1701, x-ibm1702, x-ibm1703, x-ibm1704, x-ibm1705,
x-ibm1706, x-ibm1707, x-ibm1708, x-ibm1709, x-ibm1710, x-ibm1711,
x-ibm1712, x-ibm1713, x-ibm1714, x-ibm1715, x-ibm1716, x-ibm1717,
x-ibm1718, x-ibm1719, x-ibm1720, x-ibm1721, x-ibm1722, x-ibm1723,
x-ibm1724, x-ibm1725, x-ibm1726, x-ibm1727, x-ibm1728, x-ibm1729,
x-ibm1730, x-ibm1731, x-ibm1732, x-ibm1733, x-ibm1734, x-ibm1735,
x-ibm1736, x-ibm1737, x-ibm1738, x-ibm1739, x-ibm1740, x-ibm1741,
x-ibm1742, x-ibm1743, x-ibm1744, x-ibm1745, x-ibm1746, x-ibm1747,
x-ibm1748, x-ibm1749, x-ibm1750, x-ibm1751, x-ibm1752, x-ibm1753,
x-ibm1754, x-ibm1755, x-ibm1756, x-ibm1757, x-ibm1758, x-ibm1759,
x-ibm1760, x-ibm1761, x-ibm1762, x-ibm1763, x-ibm1764, x-ibm1765,
x-ibm1766, x-ibm1767, x-ibm1768, x-ibm1769, x-ibm1770, x-ibm1771,
x-ibm1772, x-ibm1773, x-ibm1774, x-ibm1775, x-ibm1776, x-ibm1777,
x-ibm1778, x-ibm1779, x-ibm1780, x-ibm1781, x-ibm1782, x-ibm1783,
x-ibm1784, x-ibm1785, x-ibm1786, x-ibm1787, x-ibm1788, x-ibm1789,
x-ibm1790, x-ibm1791, x-ibm1792, x-ibm1793, x-ibm1794, x-ibm1795,
x-ibm1796, x-ibm1797, x-ibm1798, x-ibm1799, x-ibm1800, x-ibm1801,
x-ibm1802, x-ibm1803, x-ibm1804, x-ibm1805, x-ibm1806, x-ibm1807,
x-ibm1808, x-ibm1809, x-ibm1810, x-ibm1811, x-ibm1812, x-ibm1813,
x-ibm1814, x-ibm1815, x-ibm1816, x-ibm1817, x-ibm1818, x-ibm1819,
x-ibm1820, x-ibm1821, x-ibm1822, x-ibm1823, x-ibm1824, x-ibm1825,
x-ibm1826, x-ibm1827, x-ibm1828, x-ibm1829, x-ibm1830, x-ibm1831,
x-ibm1832, x-ibm1833, x-ibm1834, x-ibm1835, x-ibm1836, x-ibm1837,
x-ibm1838, x-ibm1839, x-ibm1840, x-ibm1841, x-ibm1842, x-ibm1843,
x-ibm1844, x-ibm1845, x-ibm1846, x-ibm1847, x-ibm1848, x-ibm1849,
x-ibm1850, x-ibm1851, x-ibm1852, x-ibm1853, x-ibm1854, x-ibm1855,
x-ibm1856, x-ibm1857, x-ibm1858, x-ibm1859, x-ibm1860, x-ibm1861,
x-ibm1862, x-ibm1863, x-ibm1864, x-ibm1865, x-ibm1866, x-ibm1867,
x-ibm1868, x-ibm1869, x-ibm1870, x-ibm1871, x-ibm1872, x-ibm1873,
x-ibm1874, x-ibm1875, x-ibm1876, x-ibm1877, x-ibm1878, x-ibm1879,
x-ibm1880, x-ibm1881, x-ibm1882, x-ibm1883, x-ibm1884, x-ibm1885,
x-ibm1886, x-ibm1887, x-ibm1888, x-ibm1889, x-ibm1890, x-ibm1891,
x-ibm1892, x-ibm1893, x-ibm1894, x-ibm1895, x-ibm1896, x-ibm1897,
x-ibm1898, x-ibm1899, x-ibm1900, x-ibm1901, x-ibm1902, x-ibm1903,
x-ibm1904, x-ibm1905, x-ibm1906, x-ibm1907, x-ibm1908, x-ibm1909,
x-ibm1910, x-ibm1911, x-ibm1912, x-ibm1913, x-ibm1914, x-ibm1915,
x-ibm1916, x-ibm1917, x-ibm1918, x-ibm1919, x-ibm1920, x-ibm1921,
x-ibm1922, x-ibm1923, x-ibm1924, x-ibm1925, x-ibm1926, x-ibm1927,
x-ibm1928, x-ibm1929, x-ibm1930, x-ibm1931, x-ibm1932, x-ibm1933,
x-ibm1934, x-ibm1935, x-ibm1936, x-ibm1937, x-ibm1938, x-ibm1939,
x-ibm1940, x-ibm1941, x-ibm1942, x-ibm1943, x-ibm1944, x-ibm1945,
x-ibm1946, x-ibm1947, x-ibm1948, x-ibm1949, x-ibm1950, x-ibm1951,
x-ibm1952, x-ibm1953, x-ibm1954, x-ibm1955, x-ibm1956, x-ibm1957,
x-ibm1958, x-ibm1959, x-ibm1960, x-ibm1961, x-ibm1962, x-ibm1963,
x-ibm1964, x-ibm1965, x-ibm1966, x-ibm1967, x-ibm1968, x-ibm1969,
x-ibm1970, x-ibm1971, x-ibm1972, x-ibm1973, x-ibm1974, x-ibm1975,
x-ibm1976, x-ibm1977, x-ibm1978, x-ibm1979, x-ibm1980, x-ibm1981,
x-ibm1982, x-ibm1983, x-ibm1984, x-ibm1985, x-ibm1986, x-ibm1987,
x-ibm1988, x-ibm1989, x-ibm1990, x-ibm1991, x-ibm1992, x-ibm1993,
x-ibm1994, x-ibm1995, x-ibm1996, x-ibm1997, x-ibm1998, x-ibm1999,
x-ibm2000, x-ibm2001, x-ibm2002, x-ibm2003, x-ibm2004, x-ibm2005,
x-ibm2006, x-ibm2007, x-ibm2008, x-ibm2009, x-ibm2010, x-ibm2011,
x-ibm2012, x-ibm2013, x-ibm2014, x-ibm2015, x-ibm2016, x-ibm2017,
x-ibm2018, x-ibm2019, x-ibm2020, x-ibm2021, x-ibm2022, x-ibm2023,
x-ibm2024, x-ibm2025, x-ibm2026, x-ibm2027, x-ibm2028, x-ibm2029,
x-ibm2030, x-ibm2031, x-ibm2032, x-ibm2033, x-ibm2034, x-ibm2035,
x-ibm2036, x-ibm2037, x-ibm2038, x-ibm2039, x-ibm2040, x-ibm2041,
x-ibm2042, x-ibm2043, x-ibm2044, x-ibm2045, x-ibm2046, x-ibm2047,
x-ibm2048, x-ibm2049, x-ibm2050, x-ibm2051, x-ibm2052, x-ibm2053,
x-ibm2054, x-ibm2055, x-ibm2056, x-ibm2057, x-ibm2058, x-ibm2059,
x-ibm2060, x-ibm2061, x-ibm2062, x-ibm2063, x-ibm2064, x-ibm2065,
x-ibm2066, x-ibm2067, x-ibm2068, x-ibm2069, x-ibm2070, x-ibm2071,
x-ibm2072, x-ibm2073, x-ibm2074, x-ibm2075, x-ibm2076, x-ibm2077,
x-ibm2078, x-ibm2079, x-ibm2080, x-ibm2081, x-ibm2082, x-ibm2083,
x-ibm2084, x-ibm2085, x-ibm2086, x-ibm2087, x-ibm2088, x-ibm2089,
x-ibm2090, x-ib
```

业务功能接口调用案例3

提示发送短信发送频率每隔60秒才能发送一次。利用空格、加号或换行符等特殊字符绕过短信频率限制。

Request

Raw Params Headers Hex

```
POST /.../send HTTP/1.1
Host: ...
Connection: keep-alive
Content-Length: 37
Accept: application/json, text/plain, */*
Origin: file://
User-Agent: Mozilla/5.0 (Linux; Android 6.0.1; Nexus 6P; Build/MMB29M; wv) AppleWebKit/537.36 (KHTML, like Gecko) Version/4.0 Chrome/55.0.2883.91 Mobile Safari/537.36 tsClient
Authorization: ...
Content-Type: application/json; charset=UTF-8
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,en-US;q=0.8
Cookie: ...
X-Requested-With: XMLHttpRequest
```

`{\"phone\":\"13800138000\"}`

Response

Raw Headers Hex

```
HTTP/1.1 200 OK
Server: nginx
Date: Mon, ...
Content-Type: application/json; charset=UTF-8
Connection: keep-alive
Vary: Accept-Encoding
Content-Length: 146
```

`{\"code\":\"CC_MESSAGE_YDM_DUPLICATE_ERROR\", \"params\":null, \"message\":\"验证码已存在, 请稍后再试\", \"data\":null}`

连续多次发送验证码，提示间隔时间过短

Request

Raw Params Headers Hex

```
POST /.../send HTTP/1.1
Host: ...
Connection: keep-alive
Content-Length: 37
Accept: application/json, text/plain, */*
Origin: file://
User-Agent: Mozilla/5.0 (Linux; Android 6.0.1; Nexus 6P; Build/MMB29M; wv) AppleWebKit/537.36 (KHTML, like Gecko) Version/4.0 Chrome/55.0.2883.91 Mobile Safari/537.36 tsClient
Authorization: ...
Content-Type: application/json; charset=UTF-8
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,en-US;q=0.8
Cookie: ...
X-Requested-With: XMLHttpRequest
```

`{\"phone\":\"13800138000 \"}`

Response

Raw Headers Hex

```
HTTP/1.1 200 OK
Server: nginx
Date: Mon, ...
Content-Type: application/json; charset=UTF-8
Connection: keep-alive
Vary: Accept-Encoding
Content-Length: 80
```

`{\"code\":\"SUCCESS\", \"params\":null, \"message\":null, \"data\":null}`

在手机号后加一个空格发现又成功发送了

业务功能接口调用案例4

有的功能接口通过限制IP的思路，这种可能通过XFF头进行实现。

```
POST /like_do.php HTTP/1.1
Host:
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:92.0) Gecko/20100101 Firefox/92.0
Accept: application/json, text/javascript, */*; q=0.01
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
X-Requested-With: XMLHttpRequest
Content-Length: 4
Origin:
DNT: 1
Connection: close
Referer: http://news_comment.php
Cookie: PHPSESSID=1jvzp8u3gknljtjbvtfk9o2j692; uid=m233241; mid=1496b60791c763c44017d595cde36e84
X-Forwarded-For: .52285

id=7
```

惨痛案例



10:01 3.21 K/s 7%

< 详情



十二点以后用我手机号测试短信炸弹的扣工资！！

2019年9月5日 00:16



业务功能接口未授权访问

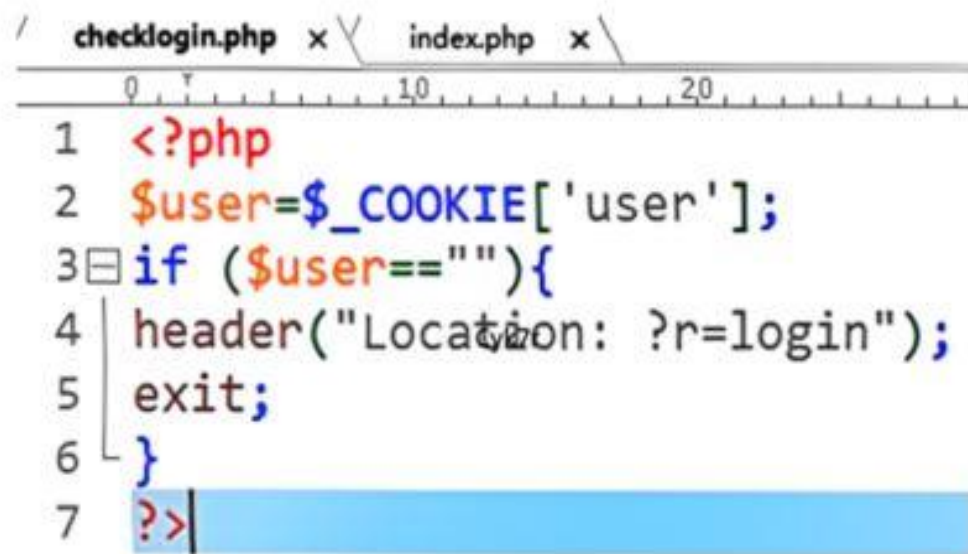
未授权访问漏洞，是在攻击者没有获取到登录权限或未授权的情况下，可直接输入网站控制台主页面地址，或者不允许查看其他的页面链接就可直接访问。



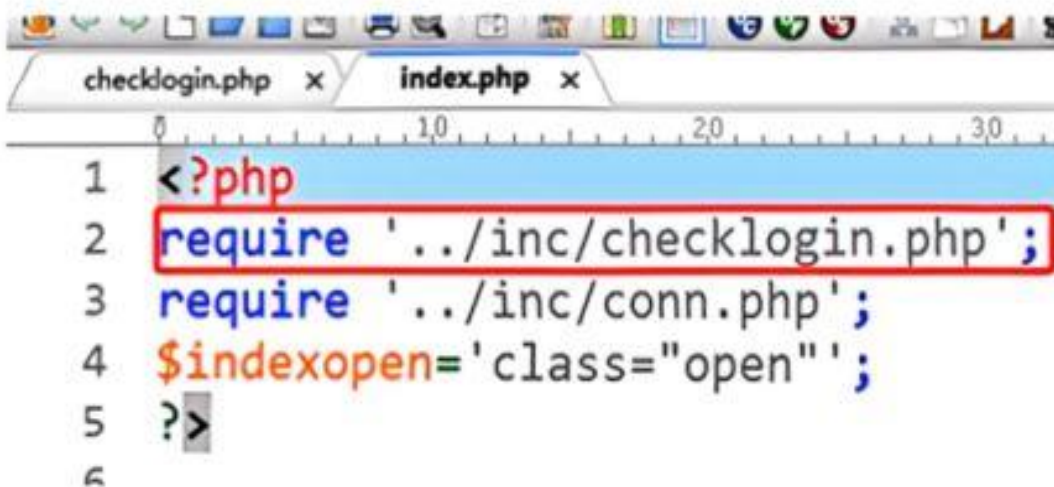
被你发现了

业务功能接口未授权访问

有的登录验证往往都是封装成一个文件，然后在需要进行登录验证的地方去包含。但网站下的文件大小小有很多，如果有文件没有包含这个登录文件的话，那这里就存在这个未授权访问。



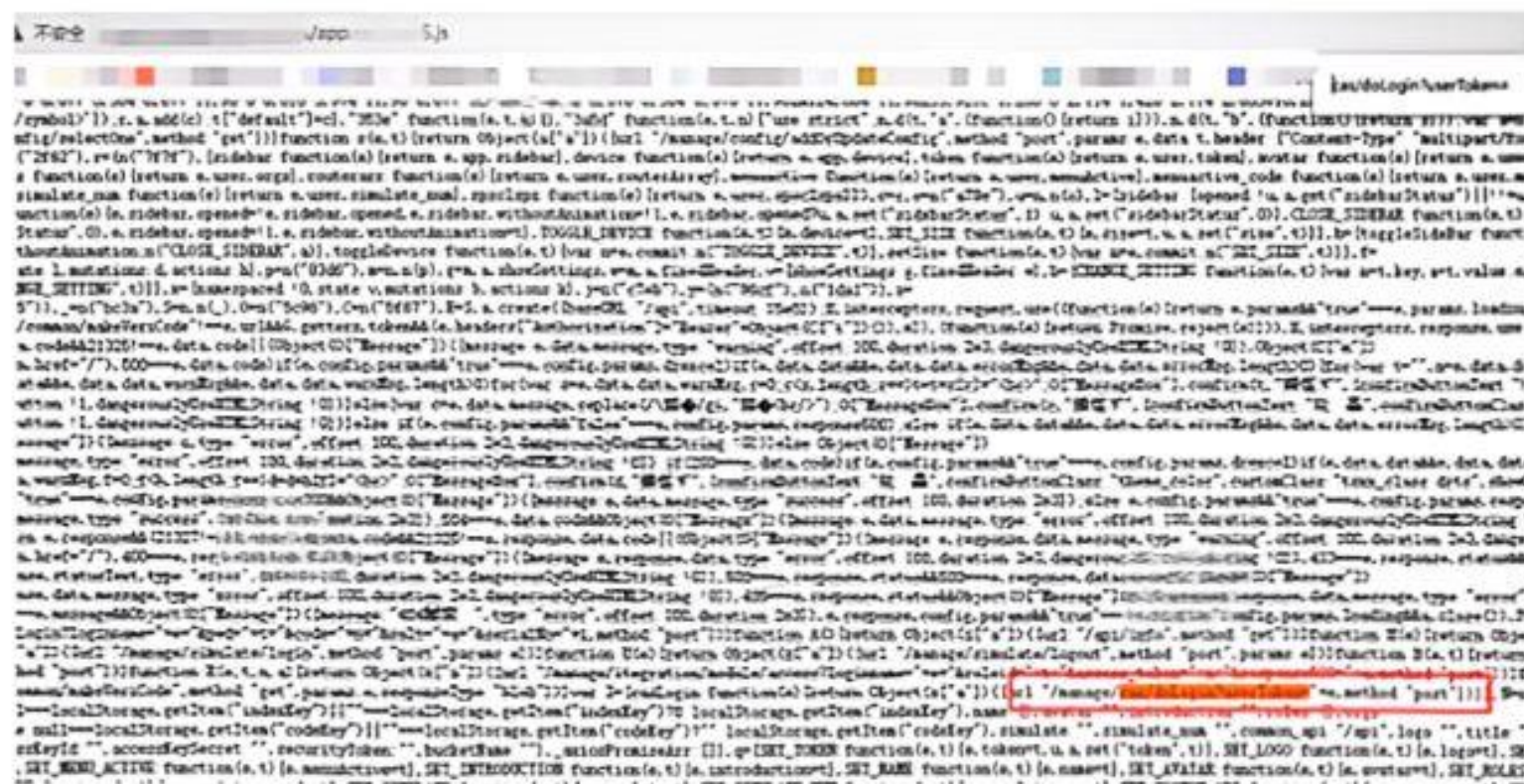
```
1 <?php
2 $user=$_COOKIE['user'];
3 if ($user==""){
4 header("Location: ?r=login");
5 exit;
6 }
7 ?>
```



```
1 <?php
2 require '../inc/checklogin.php';
3 require '../inc/conn.php';
4 $indexopen='class="open"';
5 ?>
```

业务功能接口未授权+越权漏洞案例

从JS文件中找到一处接口。发现是以post方式传递数据。



业务功能接口未授权+越权漏洞案例

通过构造数据包，获取到账号密码。

```
POST /api/manage/cas/dologin HTTP/1.1
Host:
Connection: close
sec-ch-ua: "Chromium";v="104", "Not A;Brand";v="99", "Google Chrome";v="104"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/104.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
Cookie: token=
Content-Type: application/x-www-form-urlencoded
Content-Length: 20

userToken=
```

```
Pretty Raw Render \n Actions
{
  "status": 1,
  "createtime": "2022-08-29-22-34-29",
  "children": null,
  "userorgtype": 1,
  "UserContext": {
    "userid": "1",
    "loginname": "1",
    "realname": "1",
    "password": "1",
    "photo": null,
    "telephone": null,
    "phone": null,
    "wechat": null,
    "dingding": null,
    "email": null,
    "status": 0,
    "appclientid": null,
    "department": null,
    "duty": null,
    "userRoles": [
      {
        "roleid": 2,
        "rolecode": "ROLE_TEACHER",

```


业务功能接口未授权+越权漏洞案例

通过遍历学号，找到管理员的账号，密码信息。



业务功能接口未授权访问敏感数据案例

某车企的SRC众测中发现的一个比较常见的API接口未授权漏洞，接口泄露了大量的客户敏感信息，利用这些敏感信息还可进行更深度的漏洞挖掘。

api/base/parts/getPartsOrderInfoByPartsOrderList

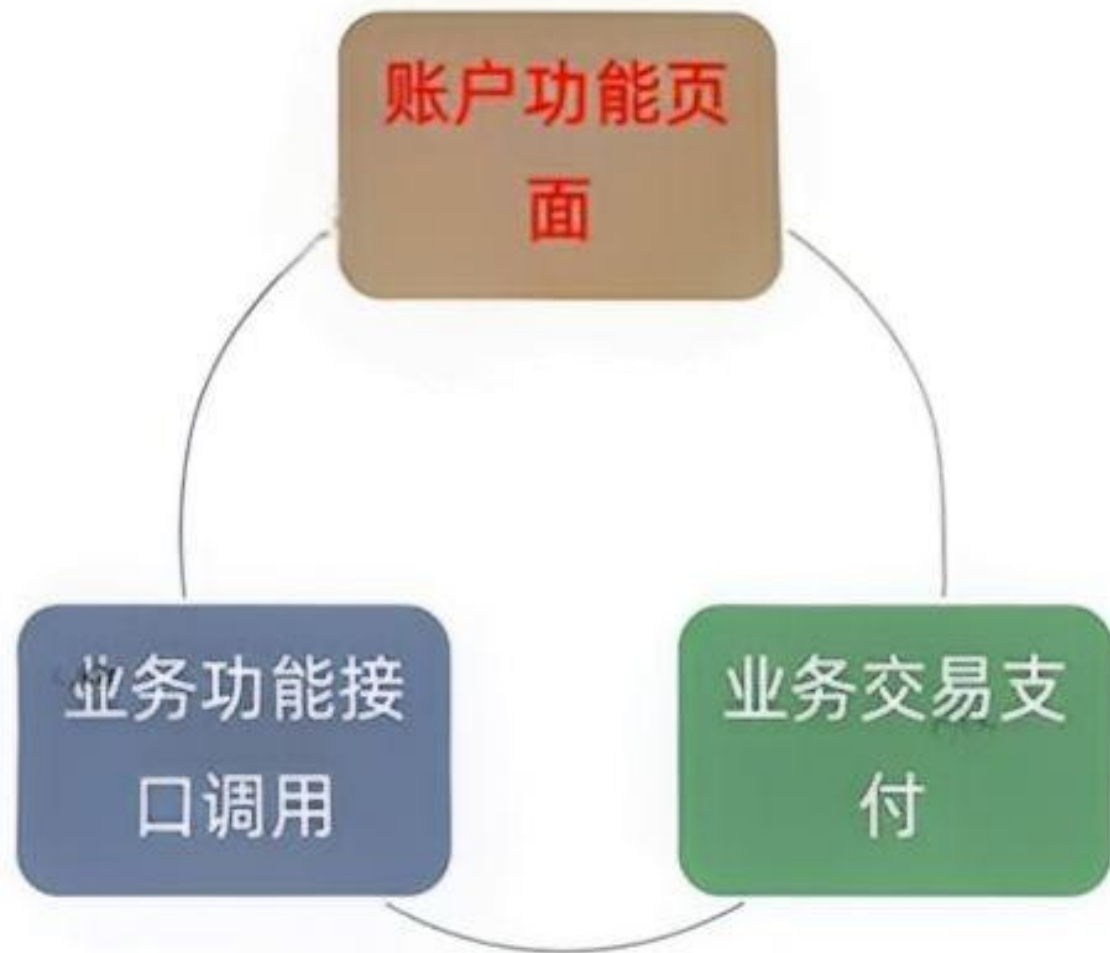
code": "400", "desEn": "Request method 'GET' not supported", "desZh": "Request method 'GET' not supported"

```
POST /api/base/parts/getPartsOrderInfoByPartsOrderList
HTTP/1.1
Host: [redacted]
Connection: close
sec-ch-ua: "Google Chrome";v="107", "Chromium";v="107", "Not-A.Brand";v="24"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "Windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/png,image/svg+xml;q=0.8,application/signed-exchange;v=b3;q=0.9
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-Dest: document
Referer: [redacted]
Accept-Language: zh-CN,zh;q=0.9
Cookie: Hm_lvt_bc38887aa5588add05a38704342ad7e8=16686749; Hm_lpvt_bc38887aa5588add05a38704342ad7e8=1668678662
Content-Length: 2
Content-Type: application/json
```

```
HTTP/1.1 200
Server: nginx
Content-Type: application/json; charset=UTF-8
Connection: close
X-Application-Context: [redacted]
Access-Control-Allow-Methods: GET, POST, OPTIONS
Access-Control-Allow-Credentials: true
Access-Control-Allow-Headers:
Accept, AuthenticationToken, fromchannel, Authorization, DNT, X-CustomHeader, Keep-Alive, User-Agent, X-Requested-With, If-Modified-Since, Cache-Control, Content-Type, jwtToken, ServiceJwtToken, UserJwtToken, xys_jwt
Content-Length: 5558
```

```
{
  "status": 1, "errorCode": null, "errMsg": null, "data": [
    {
      "ttPpDeliveryPartsId": 19, "ttPpDeliveryId": null, "deliveryNo": null, "partDeliveryNo": [redacted], "vin": null, "wmsOrderNo": null, "partsStatus": "78501020", "previousStatus": "78501020", "pairTime": null, "senderName": "联系人", "senderPhone": [redacted], "senderCode": "9601", "senderAddress": [redacted], "00号": [redacted], "senderCodeGaode": "310110", "startCoordinate": [redacted], "receiverName": [redacted], "receiverPhone": [redacted], "receiverCode": "4115020", "receiverCodeGaode": "210114", "receiverAddress": [redacted], "endCoordinate": [redacted], "standardBoxVolume": [redacted], "tankVolume": null, "standardBoxQuantity": 1, "upPartsCreationTime": [redacted]
    }
  ]
}
```

常见漏洞出现点



用户名枚举

通过判断用户是否已注册，从海量用户中筛选出有效用户；

登录到博客园

用户名

dudu

密码

[忘记密码](#)

☐ 保存密码

登 录

[取消登录](#)

[注册](#) [忘记密码](#) [忘记用户名](#)

[返回首页](#) [联系我们](#)

密码错误!

登录到博客园

用户名

dudu123456

密码

[忘记密码](#)

☐ 保存密码

登 录

[取消登录](#)

[注册](#) [忘记密码](#) [忘记用户名](#)

[返回首页](#) [联系我们](#)

该用户不存在!

会话固定

Session会话固定攻击是一种诱骗受害者使用攻击者指定的Session的攻击手段。



空口令

当找到网站登录页面，尝试输入用户名，不使用密码直接进行登录。若是不使用密码直接登录则存在空口令。



登入

登入

名稱：

密碼：

登入

登陆验证加密绕过

服务器需要判断传过来的参数带有是否加密的然后才会对其验证，但并不知道我们并不知道算法。

```
9 Accept-Encoding: gzip, deflate
10 Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
11 x-forwarded-for: 192.168.1.1
12 x-originating-ip: 192.168.1.1
13 x-remote-ip: 192.168.1.1
14 x-remote-addr: 192.168.1.1
15 Connection: close
16
17 username=admin&password=
  [redacted]&grant_type=
  password&client_secret=
  lBTqrKS0kZix0FXeZ0HRng%3D%3D&scope=app&
  client_id=1666367FA3BA4E319588EA08B6E27DSM&
  verifyCode=qnf2&randomStr=79151656988234321
  &is_encrypt=true&auth_type=account
  application/json;charset=UTF-8
11 Date: Tue, 05 Jul 2022 02:29:
12 Pragma: no-cache
13 Server: nginx
14 X-Content-Type-Options: nosniff
15 X-Frame-Options: DENY
16 X-Xss-Protection: 1; mode=block
17 Content-Length: 94
18
19 {
  "success":false,
  "code":1000,
  "message":"用户或密码错误",
  "errorType":"WARN",
  "data":null
}
```

登陆验证加密绕过

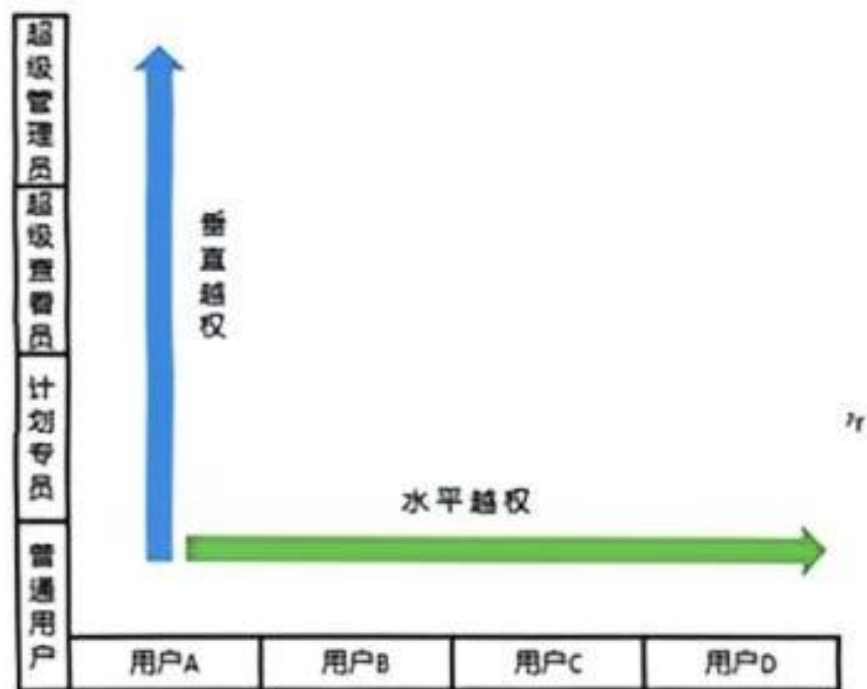
修改该参数使用明文登陆，利用该漏洞进行明文爆破。

```
x-remote-addr: 127.0.0.1
Connection: close
username=...S&password=S'...'&grant_type
=password&client_secret=
lBTqrKS0kZix0FXeZ0HRng%3D%3D&scope=app&
client_id=1666367FA3BA4E319588EA08B6E27DSM&
verifyCode=gaf2&randomStr=79151656988234321
&is_encrypt=false&auth_type=account|
```

```
15 X-Frame-Options: DENY
16 X-Xss-Protection: 1; mode=block
17 Content-Length: 91
18
19 {
  "access_token":
    "c5a91753-e51e-4053-a19c-e7fa69151326",
  "token_type": "bearer",
  "scope": "app"
}
```

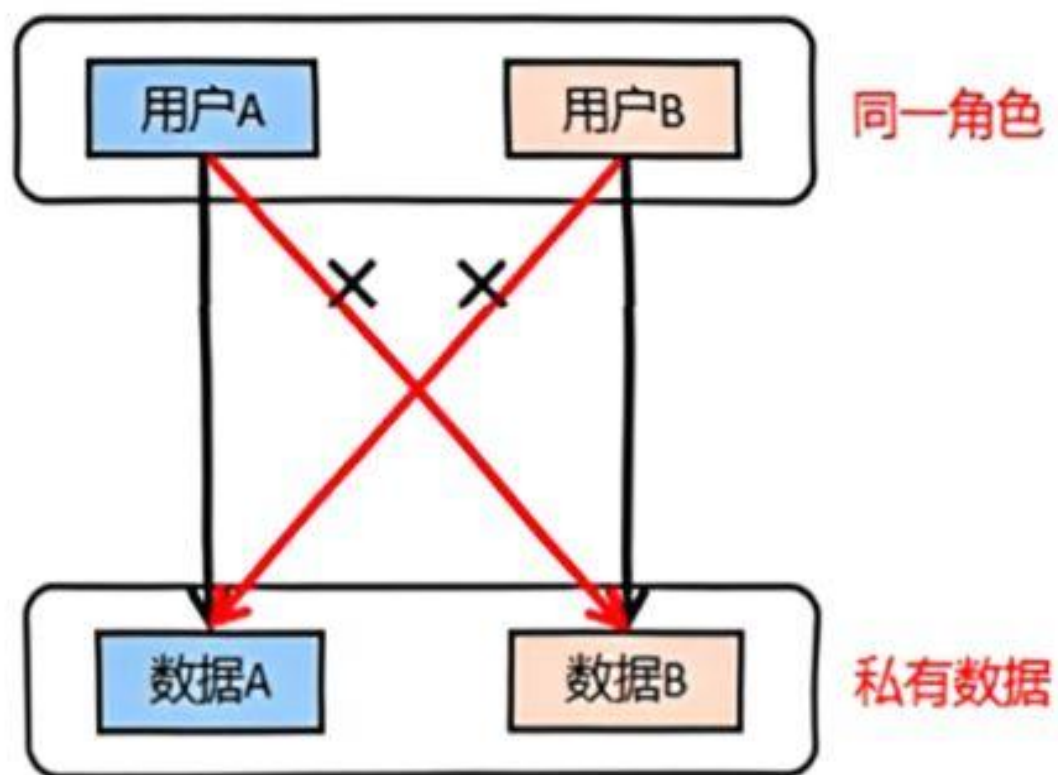

越权漏洞

由于没有对用户权限进行严格的判断，导致低权限的账号（比如普通用户）可以去完成高权限账号（比如超管）范围内的操作，如果能够成功操作，则称之为越权操作。越权漏洞形成的原因是后台使用了不合理的权限校验规则导致的。



水平越权

水平越权漏洞指攻击者尝试访问或操作与他拥有相同权限的用户资源。



水平越权案例

学生账户间水平越权访问他人信息，该案例是某高校的一个与考生相关的信息系统，在这个信息系统中，学生账户登录后，就可以查询和下载自己的考生信息表。

1 / 6

考生申请表

个人信息

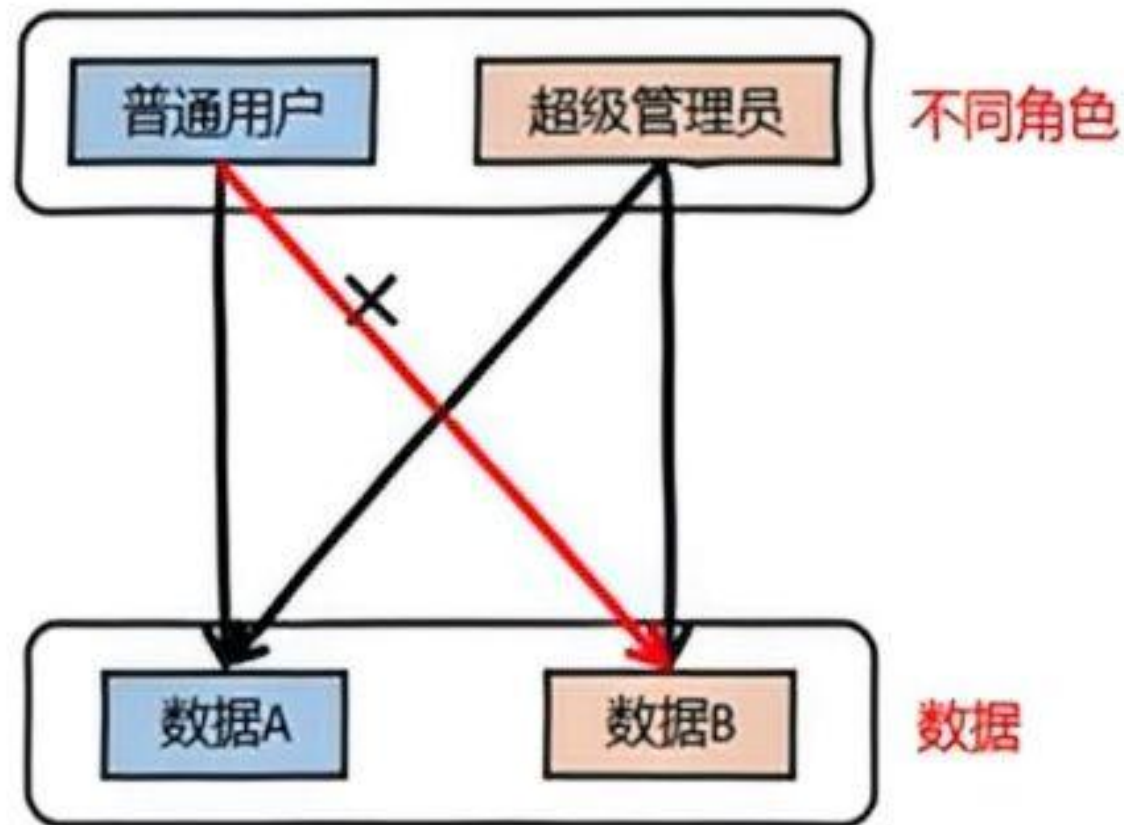
姓名:	性别:	男
婚姻状况:	身份证号:	
户籍所在地:	手机号码:	1
电子邮箱:		
邮政编码:		
邮寄地址:		

紧急联系人信息

姓名:	性别:	
与你的关系:	手机号码:	

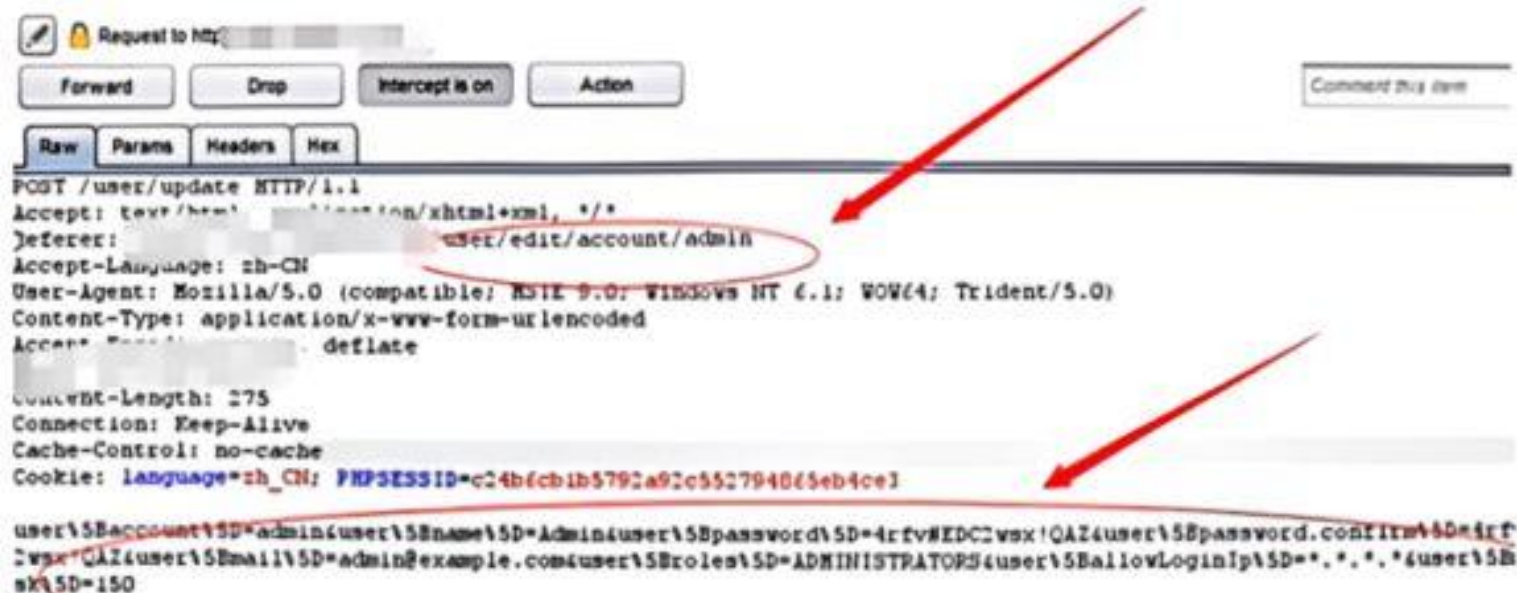
垂直越权

垂直越权就是通过自身低权限账号去执行高权限账号所能执行的操作。



垂直越权案例

审计账户登陆，修改审计员密码，抓包，将 referer 处和 post 的数据里面的 auditor 一律修改为 admin 账号。



垂直越权案例

放过数据包后，直接返回给我们超级管理员的密码修改页面，利用逻辑错误直接得到超级权限。

管理员姓名	Admin	最多20个字符
密码		密码强度不够，请包含数字、字母、@、#、\$、^、_中的至少两类。
密码确认		如果不修改密码，请留空
电子邮箱	admin@example.com	example@hotmail.com
允许登录的IP范围	*.*.*.*	IP的格式如下（多个IP范围或多个独立IP之间可用“,”、 192.168.0.1 192.168.1.1-254 192.168.1.*
允许扫描的IP范围		
允许扫描的域名范围		
最大任务存放数	150	

垂直越权案例2

通过burp进行抓包，发现在教师用户登录认证成功后，服务器向客户端发送的http响应包中包含一个roletypes:[1]的字段。而接下来页面首先会重定向到选择学生入学年级，而此时页面中显示当前用户的角色为指导教师，



垂直越权案例2

猜roletypes很可能是开发人员定义的角色类型，改参数roletypes:[5]，此时重定向的页面显示当前身份为管理员，选择年级后，就进入了管理员的后台。



垂直越权案例3

信息发布是在高校的大多数信息系统中都存在的功能，发布的信息往往会显示在网站的首页，所以发布信息往往是管理员才拥有的高权限动作。



垂直越权案例3

管理员可点击新增会跳转至新增页面，URL地址为：`http://XXXXX/news/create`。此URL，属于管理员才可以访问的URL，对低权限账号也采取了隐藏措施，但是对于有经验的攻击者来说，显然并不难猜，或者通过爬虫等手段均可以轻松访问到该URI



验证码

验证码这里指的是图形验证码使用过一次未立即失效引起的问题、验证码可能遭到爆破的问题、验证码可预测的问题以及万能验证码等等。



然而并没有什么卵用

万能验证码

为了方便测试加了888888、000000这样的万能验证码。但上线后没删除，导致被恶意利用。

请输入您的手机号完成验证，找回密码

手机号

验证码

获取验证码

新密码

密码长度请控制在6 - 20个字符



验证码复用

验证码复用指的是图形验证码使用过一次未立即失效引起的问题，在遇到的案例中，都是那种验证码使用后依然可以继续使用。



验证码回显

再调用短信平台或者邮箱平台的时候，没有判定验证码和手机号或者邮件进行绑定，并且把验证码检验直接放在客户端的返回数据包中，从而导致验证码在客户端中显示。

验证码登录 扫码登录 微信登录

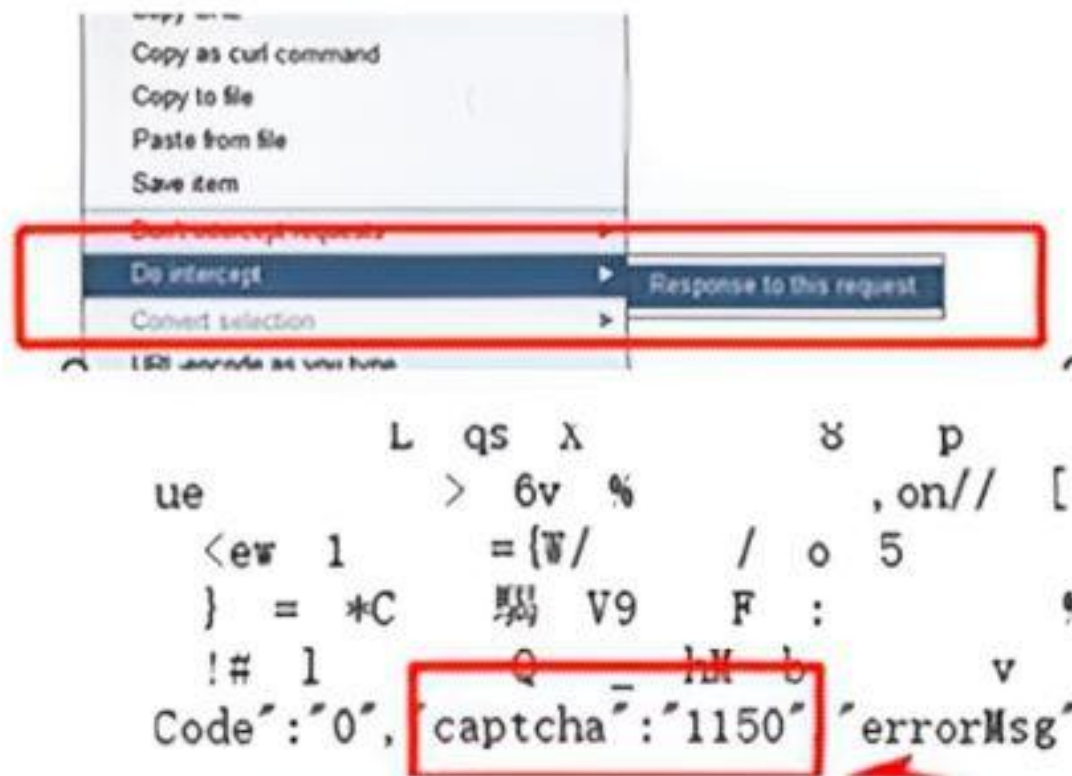
国家和地区

中国

+86 15

请输入收到的验证码

获取验证码



验证码回显 (变种)

在请求可以看到有一个参数_captcha_bankcoas_key=, 这个值怎么看都像是用了base64编码, 当然不排除是加密算法加密之后再次使用base64进行编码。

Request

Raw Params Headers Hex

```
GET /captcha.htm HTTP/1.1
Host: [REDACTED]
Connection: close
User-Agent: Mozilla/5.0 (Linux; Android 9; EKL-AL20
Build/WHYHIHKL-AL20; wv) AppleWebKit/537.36 (KHTML, like
Gecko) Version/4.0 Chrome/71.0.3578.99 Mobile Safari/537.36
Accept: image/webp,image/apng,image/*,*/*; q=0.8
Referer: https://[REDACTED]
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,en-US;q=0.9
Cookie: JSESSIONID=E3AD54 [REDACTED]
userSig=R020 [REDACTED]
DTsTA4R:WtW [REDACTED]
VU3PQYUNG:4775 [REDACTED]
sto-id-39199=1P82F [REDACTED]
Ha_lvt_1cf88a7e2162282d3d8a290d13cbf4a2=1552903412,1552978129,
1553047809,1553048674
Ha_lvt_1cf88a7e2162282d3d8a290d13cbf4a2=1553048674
```

Response

Raw Headers Hex Render

```
HTTP/1.1 200 OK
Date: [REDACTED]
Server: Apache-Coyote/1.1
Expires: Thu, 01 Jan 1970 00:00:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Cache-Control: post-check=0, pre-check=0
Pragma: no-cache
Content-Type: image/jpeg charset=utf8
Set-Cookie: _captcha_bankcoas_key="DT15C7Y5WJAA0PTT7YJ8JNDJH0B0M-64M0Pj00QWJ0;
RTU1WzA4R:WtW [REDACTED] Version= [REDACTED] Expires=Wed,
27-Mar-2019 02:34:19 GMT. Path=/
Set-Cookie: sto-id-39199=1P82FAAJJEP, Expires=Sat, 17-Mar-2029
02:35:02 GMT. Path=/
Connection: close
Content-Length: 2527
```


验证码回显 (变种)

黄色箭头部分为密文形式

ZTI5ZTVhNjA4NWY0YjNjNDJhNDE0MjdkNzFjODQxMjUjMTU1MzA0OTI1QjQ3MSM2MDQ4MDAj
TWprM1lqUTNNV0V3TjJZelpXRm1aVFUzWXpBeE5tRmxPR0kxTnpabE56ST0=

进行一次base64解码

e29e5a6085f4b3c42a41427d71c84125#1553049259471#604800#Mjk3YjQ3MWEwN2YzZWFl
mZTU3YzAxNmFLOGI1NzZlNzI=

#号到结尾的部分再次进行base64解码

297b471a07f3eafe57c016ae8b576e72

进行md5解密

密文:	297b471a07f3eafe57c016ae8b576e72
类型:	自动 ▼ [帮助]
查询 加密	

查询结果:
559467

验证码爆破

手机或邮箱验证码可爆破。因为没有对应的手机号或邮箱，但如果验证码纯数字4位，服务器未对验证码的验证次数，频率限制则存在爆破的可能。

短信

昨天 上午7:46



虚假验证码

此接口用户绑定用户的微信和手机号，

手机号

14474527001

密码

验证码

123456

获取验证码

虚假验证码

第一次密码输入错误，提示账号或密码错误

Connection: close

```
{
  "phoneNum": "14474527001",
  "password": "abc2222222",
  "yzm": "123456",
  "openId": "oYE41E"
}
```

```
11
12 {
13   "message": "账号或密码错误",
14   "status": false
15 }
```

继续使用之前的验证码，换个错误的密码输入看看，居然还是提示账号或密码错误

```
{
  "phoneNum": "14474527001",
  "password": "abc2222222",
  "yzm": "123456",
  "openId": "oYE41E"
}
```

```
12 {
13   "message": "账号或密码错误",
14   "status": false
15 }
```

那么输入正确的密码来看看呢，直接提示了用户验证码错误或已过期

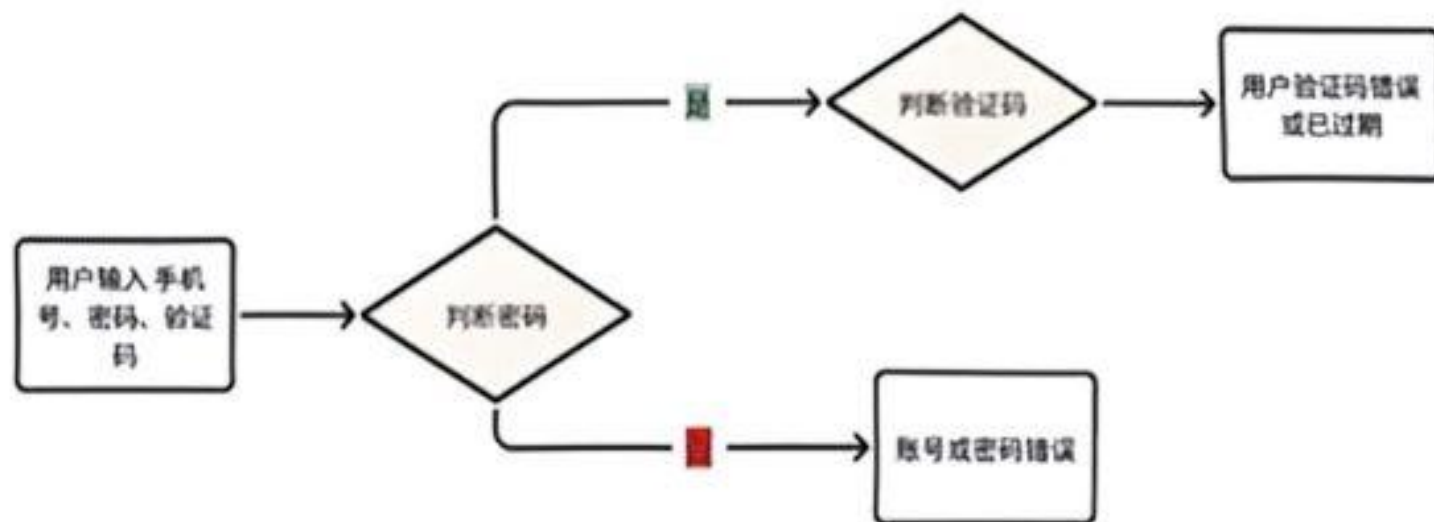
Accept-Language: zh-CN,zh;q=0.9
Connection: close

```
{
  "phoneNum": "14474527001",
  "password": "abc123456",
  "yzm": "123456",
  "openId": "oYE41E"
}
```

```
10 Access-Control-Allow-Headers: *
11
12 {
13   "message": "用户验证码错误或已过期",
14   "status": false
15 }
```


虚假验证码

这就导致一个验证码正确与否都不影响我们来穷举密码，但是当密码正确的时候，这时候才开始校验验证码是否正确。推测整体的逻辑。



认证流程绕过

在输入错误的验证码时会返回false之类的字段，如果修改response中的false为true，会识别为验证通过。



认证流程绕过案例1

国内某的开发者社区存在邀请码注册机制，需要有邀请码后方可完善资料。

██████，您好，欢迎回到██████，
您的用户信息不完善

完善信息

认证流程绕过案例1

将{"code":0,"data":false}改为{"code":0,"data":true}, 放行后, 发现浏览器已经可以到注册页面进行身份信息的注册了

提示

亲爱的 [用户名] :

本平台实行邀请码注册制, 请输入邀请码进行身份认证

邀请码:

[没有邀请码? 请联系我们](#)

注册 [进度条] 账户



请选择认证的用户类型

*注册新用户类型无法修改

认证流程绕过案例2

注册处，验证手机验证码处，通过修改响应包，或替换为自己的手机号，绕过验证码的限制，造成使用他人手机号进行注册。或者修改密码。

The screenshot shows a registration interface with three tabs: 教师 (Teacher), 学生 (Student), and 家长 (Parent). The 教师 tab is selected. Below the tabs, there are three steps: 1. 验证手机号 (Verify phone number), 2. 设置密码 (Set password), and 3. 完善信息 (完善信息) (Optional). Step 1 is highlighted with a blue circle. Below step 1, there is a text input field containing the phone number 13244444444, which is highlighted with a red box. A red arrow points from this box to a red text annotation: "注册的时候，可以故意注册，借用他人手机号，随便输入一个手机号" (When registering, you can intentionally register using someone else's phone number and just enter any phone number). Below the input field, there is a 433s timer and a 433s button. To the right of the input field, there is a green checkmark and the text "手机验证通过" (Phone verification passed). Below the timer and button, there is a text input field for the verification code, which is empty. A red arrow points from the 433s button to this field. To the right of this field, there is a green checkmark and the text "验证码输入正确" (Verification code entered correctly). Below the verification code field, there is a red text annotation: "获取验证码时，拦截，将手机号替换为自己的" (When getting the verification code, intercept and replace the phone number with your own). At the top right of the interface, there is a link: 已有账号? 直接登录 (Already have an account? Log in directly).

认证流程绕过案例2

账号设置

个人信息 修改您的个人信息

基本信息 • 修改头像

姓名: aaaaaa

性别: ☐ 男 ☐ 女

身份证号: 请输入身份证号

手机号: 132****555

注册成功

认证流程绕过案例3

输入任意用户名密码，点击登陆按钮同时使用抓包工具进行数据包拦截。



认证流程绕过案例3

修改code参数。直接绕过登录后台。

X-Powered-By: PHP/5.3.38

["code":0,"msg":"用户名或密码错误"]

后台管理中心

将code修改成1即可

注册页面

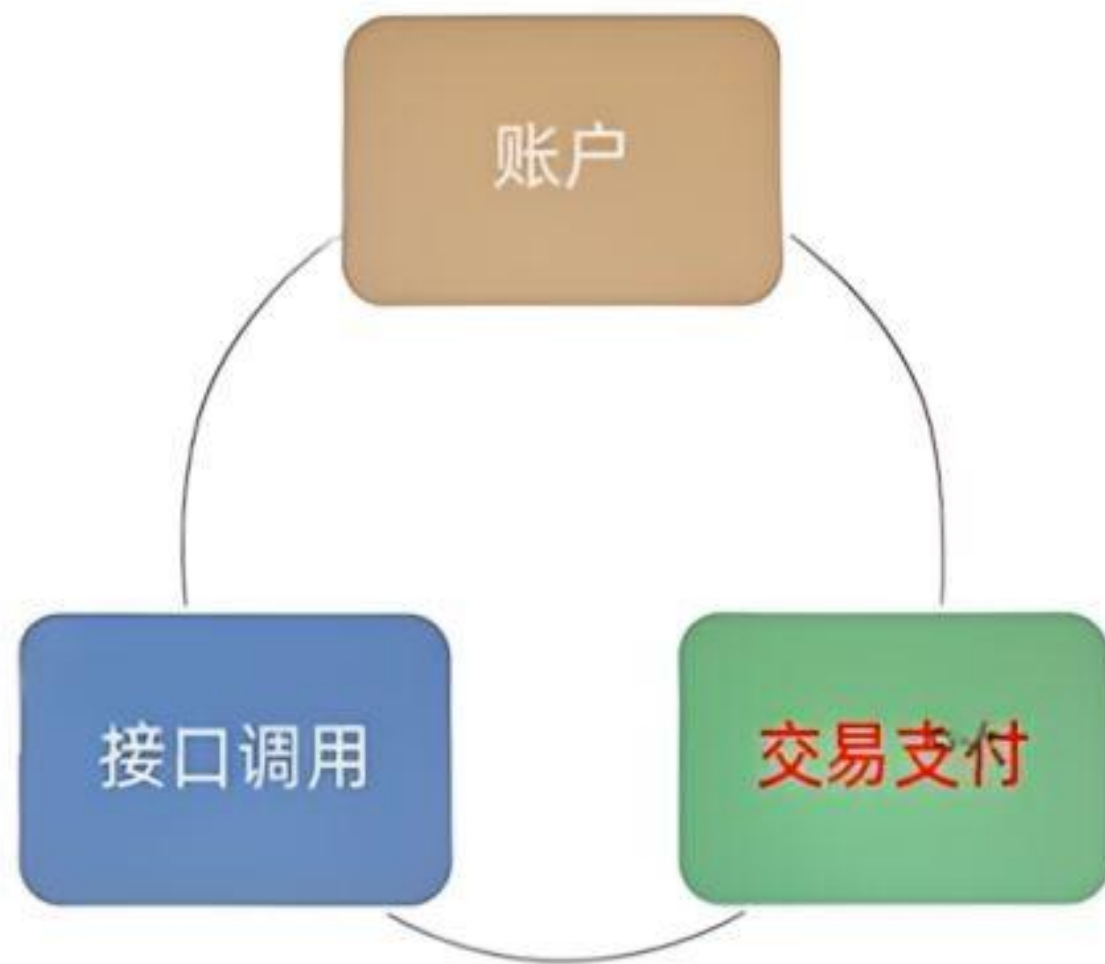
一般涉及到购物的网站都有相对应的新人优惠政策，例如注册给优惠券或者代币的活动等。

用户中心 网站首页 帐号管理 订单管理 影币记录 观看记录 我的话题 收藏 想看 在看 看过 退出

> 我的影币记录

频道	类型	变化值	操作时间
用户	注册赠送	10	2023-11-27 15:43
用户	注册赠送	10	2023-11-27 15:43
用户	注册赠送	10	2023-11-05 14:01

常见漏洞出现点



交易支付处



单价、数量、总价

关于支付处的逻辑漏洞的一般思路。包括负值反冲、正负值对冲、甚至是直接修改数量单价、总价等等。

购买学时卡——付款

应付款金额 *

1

付款方式 *



微信



支付宝



线下付款

备注 (请输入250
字以内)

单价、数量、总价案例

首先页面存在学时卡购买，加入购物车时，价格正常，此时不可以修改，否则会被拦截到。

学时卡购买 注释 学时卡购买



购物车

序号	学时数	数量	单价	金额	操作
1	10	1	123.00	123.00	移除

总金额：123.00

下一步

取消

单价、数量、总价案例

修改总价格，发送数据包，成功一元购。

.0&amount=1&price=123.00&countMoney=1.00

修改总价

购买学时卡——付款

应付款金额 *

1

付款方式 *



微信



支付宝



线下付款

金额单位

有些业务在支付时会忽略分以后的单位。比如0.019。在支付时客户端给服务器传了0.019元的订单，使用第三方支付。而第三方支付通常最小的单位为分，这就会导致返回的金额会把后面的9屏蔽掉，只返回0.01。当支付完0.01后，第三方会通知服务器支付成功。

修改支付接口

一些网站支持很多种支付，比如自家的支付工具，第三方的支付工具，然后每个支付接口值不一样，如果逻辑设计不当，当我随便选择一个点击支付时进行抓包，然后修改其支付接口为一个不存在的接口，如果没做好不存在接口相关处理，那么此时就会支付成功。

无限使用优惠券

优惠券主要用来打折或者抵扣现金，但优惠券进行消费一般会有一些使用条件。一个优惠券只能使用一次。但是有时候优惠券应该跟订单ID进行绑定。然后优惠券使用后会失效。但是如果优惠券虽然使用一次消失。但是在高并发的情况下。还是会出现单用户的优惠券重复下单的现象。如果优惠券忘记失效。也不跟订单绑定。那就会出现无限使用的现象。

前端限制限购商品

02-5-7-1

02-5-7-2

有些商品限购1个，但是判定的逻辑是通过前端判断，而不是后端。
因此可以抓包后修改购买数量。

02-5-7-3

无限制试用

在支付的商品的URL后面的支付接口是3，而试用接口是4，那么假设当前已经使用过了。复制下确认试用时的URL，修改后面的支付接口为3。那么此时就会调用购买支付接口，但是由于你本身这个产品就是试用的，其相应值绑定了这个试用商品，那么金额就肯定是0。那么最后点击支付，就可以看到支付成功，又重复试用了一次，然后试用时间会累加在一起形成可无限制试用任何产品。

越权支付

假设支付的参数中存在相关字段username=XXXXX，如果没有加以验证，其支付是一次性支付，并没有要求输入密码什么的机制。那么就可以修改这个用户ID为其它用户ID，达到用其他用户的账号进行支付的商品。

充值中放弃订单未失效

在充值中选取大额充值订单，放弃订单，获得订单号，之后充值小额订单，拿到充值成功的界面，将订单号修改为放弃的大额订单号，利用充值成功的数据包的成功随机值重放数据包。观察是否成功。

多重替换支付

首先去产生两个订单，这两个订单商品是不一样的，价格不一样，如果服务端没有做好这相关的验证，那么在支付的过程当中抓包，修改其订单id值为另一个订单id值，最后支付，这时就可能存在可以用订单一的支付价格买到订单二的商品。

篡改支付状态

没有对支付状态的值跟实际订单支付状态进行校验，或者是前端校验。
导致点击支付时抓包修改决定支付或未支付的参数为支付状态的值从而达到支付成功。

比如：购买A商品，支付时，bp抓包，观察包中是否有字段a来证明A商品是否被支付，支付参数=1时，代表支付成功，支付参数=2时，支付不成功，此时我们就可以修改a=1后放包，查看商品状态是否是已支付成功

感谢您的观看